AI-Based Phishing Detection

MUHAMMAD CHAUDRY
JOSHUA WEBBER
YASEEN ALLAN
SUFYAN IMRAN

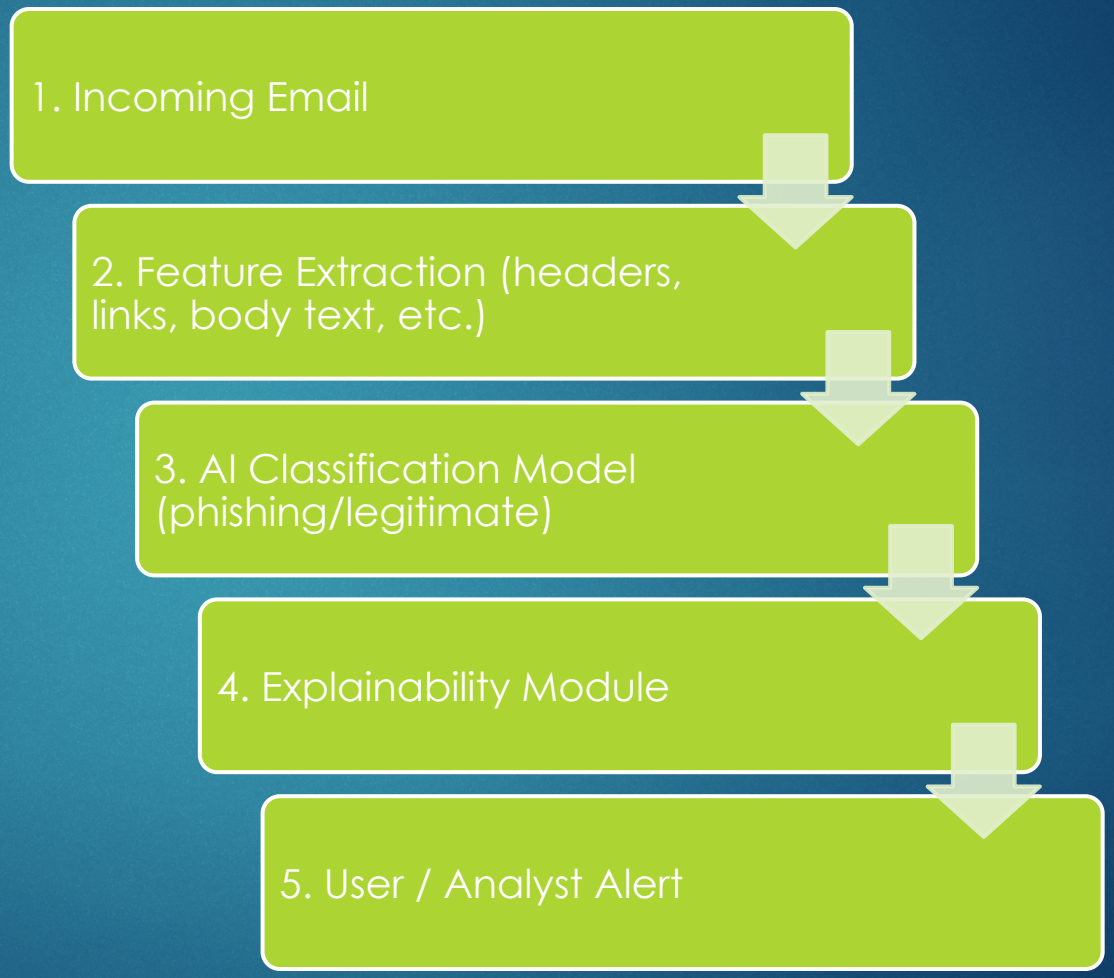
The Problem

- Modern anti-phishing techniques/tools prove themselves to be lackluster.
  - Rule-based filters often miss sophisticated variants.
  - High false positive rates are produced.
  - Lacks explanations as to why something is flagged.
    - A user becomes more vulnerable without education.
  - Consistent need to update manually-added rule/condition sets.
- There is an apparent need to solve the inefficiency and inaccuracy of current systems.

System Architecture

The provided pipeline describes the chronological order our model goes through.

- Provides:
  - Quality phishing verdicts.
  - Human-readable explanation.
- Benefits:
  - Builds trust.
  - Visibility into decision making.



Critical Assets + Risks

Assets

- User Credentials
- Corporate Emails
- AI Modelling
- Training Datasets
- Internal Network

Risks

- Credential Harvesting
- Lateral Movement
- Silent Manipulation
- Data Poisoning
- Breach/Ransomware

Asset	Type	Sensitivity	Why It Matters
Corporate email accounts	System	Critical	Compromised inbox enables lateral movement across the organization
PII and sensitive records	Data	High	Financial, health, and HR data accessible once attacker is inside
Internal network access	System	Critical	Phishing is almost always step one in a ransomware or breach campaign

Threat	Attack Vector	Impact	Likelihood
Prompt injection	Malicious instructions embedded in email body	Explainability layer manipulated to output false verdicts	Medium
Attachment payload bypass	Malware in attachment with completely clean body text	Clean verdict body-only scanning misses it	Medium
Supply chain attack	Compromise of third-party libraries or dataset sources	Silent model manipulation or data exfiltration	Low

Defensive Controls

Control

- CN-1. Input Sanitization
- CN-2. Punycode decoder
- CN-3. Rate Limiting
- CN-4. Audit Logging
- CN-5. Threshold Calibration

Control	Why Selected	Risk Addressed	Status
Input sanitization	Null bytes and malformed headers passed through at baseline with no validation	Header injection and malformed input	Done
Punycode URL decoder	TC-05 was a false negative on a Unicode domain string matching is not enough	Homograph attack bypass	Done

Purpose

- CN.1 -> Prevents malformed input.
- CN.2 -> Detects homograph domains.
- CN.3 -> Mitigates threshold probing.
- CN.4 -> Detects insider abuse
- CN.5 -> Reduces false positive rates

Validation Results

- (LEFT) A list of different test cases applied to the AI model, involving different variations (obvious, not so obvious, legit, etc.)
- (RIGHT) The results of implementing our defensive controls between Checkpoints 2 and 3.

Validation Process

Test ID	What It Tests	Baseline	With Controls	Change
TC-01	Obvious phishing urgent reset, suspicious TLD	PASS	PASS	No change
TC-02	Legitimate HR email from known domain	PASS	PASS	No change
TC-03	Spear phish with recipient name	FAIL	FAIL	Still open NER in progress
TC-04	Digit substitution domain paypa1.com	FAIL	FAIL	Still open
TC-05	Homograph attack Cyrillic in domain	FAIL	PASS	FIXED by punycode decoder
TC-06	Deadline reminder with urgency language	PASS	PASS	Threshold tuning maintained
TC-07	Clean body with malicious attachment	PASS	PASS	Known gap attachment not scanned
TC-08	Rate probe 8 rapid requests from one IP	PASS	PASS	Rate limiter blocks correctly
TC-09	Prompt injection in email body	FAIL	FAIL	Still open scoring not high enough
TC-10	Team member trying to edit whitelist	PASS	PASS	Access control blocks correctly

Results

Metric	Baseline (CP2)	With Controls (CP3)	Change
Overall pass rate	6 of 10 60%	7 of 10 70%	+10 percentage points
Detection threshold	0.65	0.70	Raised to reduce false positives
Homograph attacks caught	0 of 1	1 of 1	TC-05 fixed by punycode decoder
False positive rate (TC-06)	Passing already	Passing still	Maintained correctly
Rate probing blocked	Blocked	Blocked	Working in both modes
Config write access	Open to all	Project lead only	Access hardened
Analyst feedback auditability	None	Full append-only log	New control fully deployed
Prompt injection surface	Open	Closed feature values only	New control deployed
Open test failures	4 of 10	3 of 10	One resolved this checkpoint

Final Recommendations

- Rec. 1: Schedule Monthly Revalidations
  - Datasets used for testing are significantly outdated. Further use of the model will require more recent data.
- Rec. 2: Expand test casing
  - 10 cases were enough for basic control validation; however, further testing is needed to produce accurate metrics.
- Rec. 3: Implement Named-Entity Recognition
  - There is currently no system in place to capture external senders referencing internal context, such as a name and a role. This should be incorporated for further model accuracy improvements.